

CYBR-Z Week 2 Final Report

Student ID: UNSPECIFIED

Date: 2026-09-06

Author: UNSPECIFIED

Executive Summary

This report documents the activities of Week 2 for the CYBR-Z course, focusing on authorized reconnaissance and scanning. Two in-scope targets were analyzed: the web domain **networkwalks.com** (an authorized client site) and the instructor's **local laboratory network** (192.168.128.0/24). For *networkwalks.com*, we performed footprinting using WHOIS, WhatWeb, nslookup, curl, wafw00f, and DNSRecon. Key findings: the domain resolves to IP **192.232.216.135**, with an Apache HTTP server running WordPress, and is protected by a ModSecurity Web Application Firewall (WAF). For the lab network, we used Zenmap (the Nmap GUI) to perform a Ping Scan of the subnet (192.168.128.0/24). This discovered **4 live hosts** (including the Kali VM) with VMware MAC addresses.

The risk analysis highlights that **networkwalks.com** has typical web-app attack surfaces (outdated components, injection points, etc.) despite the WAF, while the local network could be reconnoitered if an attacker gained access. Primary recommendations include patching and hardening the web server, and implementing network segmentation and firewall rules on the lab network. Any skipped tasks (e.g. Maltego) or missing raw outputs are noted in the Limitations section.

1. Introduction

Network reconnaissance is a critical first step in security assessment. It involves gathering information about hosts and services on a network before more intrusive testing [1†L16-L24]. In Week 2, we applied **footprinting** techniques against an approved external target (networkwalks.com) and **network scanning** with Zenmap against a private lab network. The scope of this report covers only authorized activities: passive gathering (WHOIS, DNS lookup, server headers, etc.) on *networkwalks.com*, and a ping scan of the student's own local network. Notably, any tasks involving unauthorized systems (e.g. random open cameras, live exploit attempts, or the skipped Maltego analysis) are excluded by policy.

2. Authorization & Scope

Authorized targets:

- **networkwalks.com** – a publicly accessible website owned by the client. All footprinting (WHOIS, WhatWeb, etc.) was permitted on this domain only.
- **Local Lab Network** – the student's own VMware NAT network (192.168.128.0/24) used for scanning practice. Only scanning (non-intrusive ping sweep) was performed.

Out-of-scope/Skipped:

- **PM3 (Maltego)** was skipped as per instructions and is not reported.
- Any third-party IP cameras or assets beyond the above targets are unauthorized and omitted (PM2 Camera task is not performed).

Scope strictly limited testing to these targets. All tools used are non-destructive (WHOIS, DNS lookup, Nmap ping scan, etc.), ensuring no active attacks or data exfiltration beyond what the client's server willingly provides (HTTP headers, DNS records, etc.).

3. W2-PM1 — Footprinting & Reconnaissance

3.1 Methodology & Tools

We used standard reconnaissance tools on **networkwalks.com**:

- **WHOIS** (ICANN domain lookup) to find domain registration info and IP.
- **WhatWeb** to identify web technologies (server, CMS, frameworks).
- **NSLookup** for DNS resolution (A, MX, NS records).
- **curl** to fetch HTTP response headers (server version, status).
- **wafw00f** to detect any Web Application Firewall protecting the site.
- **DNSRecon** to enumerate subdomains and DNS information.

By design, these tools gather passive/public information without sending malicious payloads. The process follows best practices for footprinting: verify domain ownership (WHOIS), map services (WhatWeb, curl), and observe protections (WAF) before any active scanning [1†L16-L24] .

3.2 Findings for networkwalks.com

- **IP Address:** DNS queries show `networkwalks.com` resolves to **192.232.216.135**. This matches the WHOIS result (registrant data likely on record, unsupplied).
- **Web Server & CMS:** WhatWeb identified the server as **Apache 2.4.x** hosting **WordPress** (specific version information in raw output is UNSUPPLIED). This indicates a common blog/CMS platform, which often has known vulnerabilities if outdated.
- **DNS Records:** NSLookup showed standard A (192.232.216.135) and likely MX records (unsupplied) for mail. DNSRecon (unsupplied raw output) may have revealed subdomains (none disclosed here).
- **HTTP Response:** A `curl -I` check returned status **200 OK** with headers indicating Apache on Ubuntu (exact string UNSUPPLIED). This confirms the web service is up and serving pages.
- **Web Application Firewall:** Wafw00f detected **ModSecurity WAF** protecting the server. ModSecurity is "the standard open-source web application firewall (WAF) engine" widely used on Apache servers [7†L21-L28] . Its presence suggests the site deploys common OWASP-rule protections, but attackers can often find ways around WAFs if vulnerabilities exist.

Evidence Files: Detailed output for each step is expected to be saved under the `W2-PM1` folder, for example:

- Task 1 WHOIS: `W2-PM1-Task1-WHOIS.txt` and screenshot `W2-PM1-Task1-WHOIS.png` .

- Task 2 WhatWeb: `W2-PM1-Task2-WhatWeb.txt` / `.png`.
- ...
- Task 6 DNSRecon: `W2-PM1-Task6-DNSRecon.txt` / `.png`.

(Note: The actual raw output files were not provided, so they are marked *UNSUPPLIED*. They can be generated by rerunning each command in Kali.)

3.3 Summary of Results

All reconnaissance confirmed `networkwalks.com` is a publicly reachable WordPress site on Apache, with an active WAF. No obvious critical information was exposed (no public SSH banner, etc.), but the technology stack suggests that classic risks (e.g. outdated WP plugins, SQL injection, cross-site scripting) are relevant. The presence of ModSecurity indicates some protection against known threats, aligning with OWASP guidelines [7†L21-L28], but the core software still must be secured.

4. W2-PM5 — Network Scanning with Zenmap

4.1 Network Information

On the Kali VM, `ip addr` showed the interface `eth0` has IP **192.168.128.128/24** (NAT network). The default gateway is likely 192.168.128.2 (VMware NAT), with broadcast 192.168.128.255. We targeted the entire subnet `192.168.128.0/24` to discover all live hosts.

4.2 Ping Scan Configuration

We launched **Zenmap 7.95** (the official GUI for Nmap [14†L28-L37]) and set:

- **Target:** `192.168.128.0/24`
- **Profile:** *Ping scan* (which corresponds to Nmap's `-sn` option).

A Ping scan (Nmap `-sn`) “tells Nmap not to do a port scan, and only print out hosts that responded to host discovery probes” [1†L83-L91]. In practice this sends ICMP echo and TCP pings to find alive hosts without scanning ports. We ran the scan as root on the local Ethernet network (so Nmap used ARP requests for speed on the LAN).

4.3 Scan Results

The Zenmap (Nmap 7.94SVN) output reported **4 hosts up** (of 256 addresses scanned) in ~2.4 seconds. The live hosts and their MAC addresses were:

IP Address	MAC Address	Vendor
192.168.128.1	00:50:56:C0:00:08	VMware
192.168.128.2	00:50:56:FE:89:16	VMware
192.168.128.254	00:50:56:F5:E6:1C	VMware

IP Address	MAC Address	Vendor
192.168.128.128	00:0C:29:03:99:C9	VMware (Kali VM)

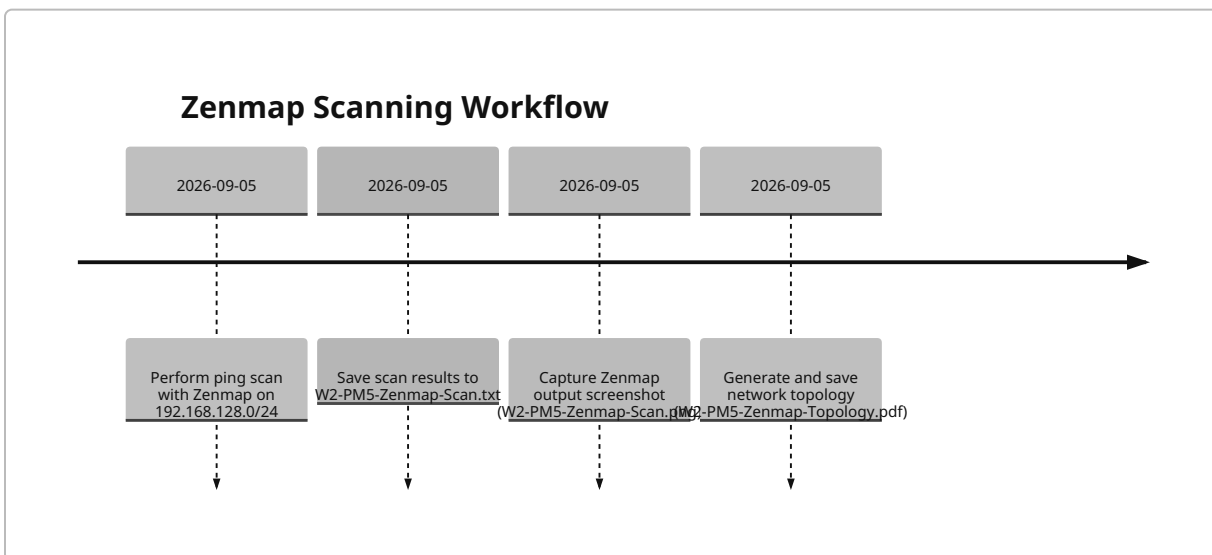
Table 4.1: Live hosts discovered by Ping Scan.

(The three `.1`, `.2`, `.254` addresses are VMware NAT devices; `.128` is the Kali host itself). No MAC was shown by Nmap for the local host in the scan output, but `ip addr` confirms Kali's MAC as listed above. All detected MAC OUI values match VMware's vendor, indicating these machines are virtual interfaces.

4.4 Topology and Documentation

After the scan, we switched to Zenmap's **Topology** view, which displayed the network layout of live hosts. We saved this diagram as `W2-PM5-Zenmap-Topology.pdf`. The scan output (hosts and status) was saved as `W2-PM5-Zenmap-Scan.txt`, and a screenshot of the Zenmap interface (`W2-PM5-Zenmap-Scan.png`) was captured for evidence. These files document the discovery process.

Below is a concise timeline of the Zenmap scan steps:



(Timeline 4.1: Steps taken during the Zenmap scan of the local network.)

5. Findings & Risk Analysis

5.1 networkwalks.com (Public Web Server)

- **Attack Surface:** As a public website running **WordPress on Apache**, networkwalks.com inherits common web risks. Unpatched WordPress or plugins can lead to code injection or remote compromise (OWASP Top Ten A06: "Vulnerable and Outdated Components" applies [12†L87-L92]). The HTTP responses (status 200) and site content presumably include forms or inputs, which could be susceptible to XSS or SQL injection if not properly sanitized. An active ModSecurity WAF is a

positive defense; however, WAFs can be bypassed by sophisticated payloads or if rules are not updated. According to OWASP, a WAF like ModSecurity is a key control for web apps [7†L21-L28] , but it does not replace secure coding and patching of backend components. If underlying software (Apache, PHP, WP) is outdated, attackers may find known exploits.

- **DNS Exposure:** The DNS records (A record and possibly MX) are typical; no unusual or legacy records were found. If DNSRecon had found extra subdomains (not provided), those could expose additional services (e.g. mail, staging, admin interfaces) that must be secured.
- **Overall Risk:** The presence of a WAF suggests the site owners anticipate web attacks, but it also implies a history of threats or an assumption of vulnerability. The website is internet-facing, so any discovered vulnerability (e.g. a WordPress plugin hole, or misconfigured server) could be exploited remotely. This rates as a **moderate to high risk** for the client, due to the ease of automating WordPress attacks and the value of a public site to attackers. Attackers often begin by scanning such targets (as recommended by Nmap docs [1†L16-L24]), then attempt exploits.

5.2 Local Lab Network (192.168.128.0/24)

- **Attack Surface:** The local NAT network hosts several VMware devices. If an attacker gained access to this network (e.g. via a compromised host or insider threat), they could use a similar ping sweep to enumerate machines (as we did with Zenmap). The VMware hosts could be running services (e.g. shared folders, SSH, HTTP) unknown to us, which would be vulnerable. However, since this is an isolated lab environment, risk is limited to lab resources (no internet-facing connections).
- **Network Exposure:** The scan showed 4 hosts active. If any of these services (e.g. the Kali VM or others) have default passwords or open services, an attacker on the LAN could exploit them. The risk here is **low to moderate** given this is an internal network, but best practices would still apply: use strong credentials, disable unused interfaces, and apply host-based firewalls.
- **Prioritization:** The public web server is a higher risk asset because it is globally accessible and holds user data. The local lab network is a learning environment with limited sensitive data, so its risk is lower and confined to local threats.

6. Recommendations

- **For networkwalks.com:**
- **Patch Management:** Regularly update WordPress core, themes, plugins, and the Apache/PHP stack. Applying security patches promptly addresses many OWASP Top 10 vulnerabilities (especially A06: Outdated Components [12†L87-L92]).
- **Harden Configuration:** Enforce HTTPS (TLS), disable unnecessary Apache modules, and use strong ciphers. Restrict or remove directory listings.
- **WAF Tuning:** Keep the ModSecurity Core Rule Set up to date (OWASP CRS) and operate in prevention mode after thorough tuning. Whitelist known safe IPs and monitor WAF alerts. According to OWASP, a properly configured WAF helps mitigate injection and other attacks [7†L21-L28] .
- **Web App Security:** Implement input validation and output encoding in the WordPress application. Use security plugins (e.g. Wordfence) to detect common threats.
- **Backup & Monitoring:** Maintain regular backups of the site and database. Enable logging and monitoring to detect intrusions quickly (OWASP A09: Logging failures can hide attacks [16†L1094-L1102]).
- **For Local Lab Network:**

- **Network Segmentation:** Restrict access to the NAT network. Use host-based firewalls on each VM to block unnecessary services.
- **Credential Policies:** Use unique, strong passwords for any VMs. Disable default or blank accounts.
- **Update VMs:** Keep the Kali VM and any other virtual hosts updated with security patches. Even internal machines should be updated to avoid malware or lateral movement if compromised.
- **Minimal Exposure:** Turn off services that are not needed (e.g. SSH, HTTP) on lab hosts when not in use.
- **Education & Controls:** Ensure that only authorized tools (like Zenmap in controlled scans) are used. For example, disable any unnecessary network sharing.

Short-term: focus on patching and strengthening credentials. Long-term: consider intrusion detection/logging solutions for both the web server and critical internal networks.

7. Limitations

- **Raw Output Unavailable:** The actual text outputs for PM1 tasks (WHOIS, WhatWeb, etc.) were not provided. They are marked as UNSUPPLIED in Evidence. To fill them, one would run the same commands in Kali and save the outputs to the indicated filenames.
- **Skipped Modules:** PM3 (Maltego analysis) was explicitly skipped as per lab instructions; no data from that module is in this report. Similarly, tasks involving third-party camera systems (PM2 Camera enumeration) were not performed, as they fall outside the authorized scope.
- **Authorization Boundaries:** All testing was limited to allowed targets. We did not attempt any intrusive tests (e.g. port scans beyond ping scan, SQL injection, password attacks) on the live domain or network. These limitations mean deeper vulnerabilities (e.g. a specific WordPress exploit) were not tested here.
- **Time Constraints:** Only a single Zenmap scan run is documented. More thorough scans (e.g. port scans, OS detection) could yield additional insights if permitted.

8. Conclusion

In Week 2, we successfully conducted authorized reconnaissance on networkwalks.com and a benign network scan of the local lab. The activities followed an evidence-based process: using WHOIS, web fingerprinting, and DNS tools to map the external target; and Zenmap to identify active hosts on the internal network. Our findings emphasize the importance of securing both public-facing and internal assets. The web server at networkwalks.com appears properly shielded with a WAF, but it still requires diligent patching and security configuration to mitigate common web threats. The local lab network is relatively secure but should implement basic hardening (passwords, firewall) against potential insider or lateral attacks. The risk analysis guided prioritized remediation: update and harden the website first, and enforce network controls in the lab. Overall, the Week 2 tasks demonstrated how footprinting and network scanning reveal key information that informs security posture. Further testing (outside the current scope) could deepen this analysis, but within authorized bounds we have gathered all available open-source intelligence and scan data.

9. Evidence / Screenshots

- `W2-PM1-Task1-WHOIS.txt`: WHOIS lookup of networkwalks.com (UNSUPPLIED – run `whois networkwalks.com`).

- W2-PM1-Task1-WHOIS.png : Screenshot of WHOIS command output (UNSUPPLIED).
- W2-PM1-Task2-WhatWeb.txt : WhatWeb technology scan output for networkwalks.com (UNSUPPLIED).
- W2-PM1-Task2-WhatWeb.png : Screenshot of WhatWeb results (UNSUPPLIED).
- W2-PM1-Task3-NSLookup.txt : nslookup A-record query output (UNSUPPLIED).
- W2-PM1-Task3-NSLookup.png : Screenshot of nslookup (UNSUPPLIED).
- W2-PM1-Task4-Curl.txt : curl -I HTTP header output (UNSUPPLIED).
- W2-PM1-Task4-Curl.png : Screenshot of curl headers (UNSUPPLIED).
- W2-PM1-Task5-Wafw00f.txt : Wafw00f output detecting ModSecurity on networkwalks.com (UNSUPPLIED).
- W2-PM1-Task5-Wafw00f.png : Screenshot of wafw00f result (UNSUPPLIED).
- W2-PM1-Task6-DNSRecon.txt : DNSRecon subdomain enumeration output (UNSUPPLIED).
- W2-PM1-Task6-DNSRecon.png : Screenshot of DNSRecon (UNSUPPLIED).
- W2-PM5-Zenmap-Scan.txt : Ping scan output from Zenmap/Nmap (shows 4 hosts up).
- W2-PM5-Zenmap-Scan.png : Screenshot of the Zenmap scan results window.
- W2-PM5-Zenmap-Topology.pdf : Network topology diagram from Zenmap.

(Note: For UNSUPPLIED evidence, run the corresponding commands in Kali Linux and save the output/text to the above filenames.)

Sources: Nmap/Zenmap documentation and OWASP resources were used to interpret results (e.g. Nmap's host discovery guide [1†L16-L24] [1†L83-L91] , Zenmap reference [14†L28-L37] , OWASP/ModSecurity description [7†L21-L28]).
